

Botium Toys: Scope, goals, and risk assessment report

Scope and goals of the audit

Scope: The scope is defined as the entire security program at Botium Toys. This means all assets need to be assessed alongside internal processes and procedures related to the implementation of controls and compliance best practices.

Goals: Assess existing assets and complete the controls and compliance checklist to determine which controls and compliance best practices need to be implemented to improve Botium Toys' security posture.

Current assets

Assets managed by the IT Department include:

- On-premises equipment for in-office business needs
- Employee equipment: end-user devices (desktops/laptops, smartphones), remote workstations, headsets, cables, keyboards, mice, docking stations, surveillance cameras, etc.
- Storefront products available for retail sale on site and online; stored in the company's adjoining warehouse
- Management of systems, software, and services: accounting, telecommunication, database, security, ecommerce, and inventory management
- Internet access
- Internal network
- Data retention and storage
- Legacy system maintenance: end-of-life systems that require human monitoring

Risk assessment

Risk description

Currently, there is inadequate management of assets. Additionally, Botium Toys does not have all of the proper controls in place and may not be fully compliant with U.S. and international regulations and standards.

Control best practices

The first of the five functions of the NIST CSF is Identify. Botium Toys will need to dedicate resources to identify assets so they can appropriately manage them. Additionally, they will need to classify existing assets and determine the impact of the loss of existing assets, including systems, on business continuity.

Risk score

On a scale of 1 to 10, the risk score is 8, which is fairly high. This is due to a lack of controls and adherence to compliance best practices.

Additional comments

The potential impact from the loss of an asset is rated as medium, because the IT department does not know which assets would be at risk. The risk to assets or fines from governing bodies is high because Botium Toys does not have all of the necessary controls in place and is not fully adhering to best practices related to compliance regulations that keep critical data private/secure. Review the following bullet points for specific details:

- Currently, all Botium Toys employees have access to internally stored data and may be able to access cardholder data and customers' PII/SPII.
- Encryption is not currently used to ensure confidentiality of customers' credit card information that is accepted, processed, transmitted, and stored locally in the company's internal database.
- Access controls pertaining to least privilege and separation of duties have not been implemented.
- The IT department has ensured availability and integrated controls to ensure data integrity.
- The IT department has a firewall that blocks traffic based on an appropriately defined set of security rules.
- Antivirus software is installed and monitored regularly by the IT department.
- The IT department has not installed an intrusion detection system (IDS).
- There are no disaster recovery plans currently in place, and the company does not have backups of critical data.
- The IT department has established a plan to notify E.U. customers within 72 hours if there is a security breach. Additionally, privacy policies, procedures, and processes have been developed and are enforced among IT department members/other employees, to properly document and maintain data.
- Although a password policy exists, its requirements are nominal and not in line with current minimum password complexity requirements (e.g., at least eight characters, a combination of letters and at least one number; special characters).
- There is no centralized password management system that enforces the password policy's minimum requirements, which sometimes affects productivity

when employees/vendors submit a ticket to the IT department to recover or reset a password.

- While legacy systems are monitored and maintained, there is no regular schedule in place for these tasks and intervention methods are unclear.
- The store's physical location, which includes Botium Toys' main offices, store front, and warehouse of products, has sufficient locks, up-to-date closed-circuit television (CCTV) surveillance, as well as functioning fire detection and prevention systems.

Controls assessment checklist

Yes	No	Control	Explanation
	X	Least Privilege	Employee access to customer data should be restricted based on job roles to minimize exposure and reduce security risks.
	X	Disaster recovery plans	There are no documented disaster recovery plans in place to respond to data loss or system failure.
	X	Password policies	The existing password policy does not meet modern security standards, requiring updates to include complexity rules.
	X	Separation of duties	Employees do not have role-based access restrictions, increasing the risk of unauthorized access.
X		Firewall	A firewall is in place and properly configured to block unauthorized traffic.
	X	Intrusion detection system (IDS)	An IDS has not been installed to detect potential security threats in real time.
	X	Backups	There are no backups of critical data, increasing the risk of permanent data loss.
X		Antivirus software	Antivirus software is installed and monitored regularly by the IT department.
	X	Manual monitoring, maintenance, and intervention for legacy systems	There is no defined schedule for monitoring and maintaining legacy systems.
	X	Encryption	Credit card and sensitive customer data are not encrypted, leaving them vulnerable to unauthorized access.
	X	Password management system	There is no centralized password management system, causing inefficiencies in password resets and recoveries.
X		Locks (offices, storefront, warehouse)	Physical locks are in place to secure the main office, storefront, and warehouse.
X		Closed-circuit television (CCTV) surveillance	CCTV surveillance is functioning and up to date.
X		Fire detection/prevention (fire alarm, sprinkler system, etc.)	Fire safety measures, including alarms and sprinklers, are in place and operational.

Compliance checklist
Payment Card Industry Data Security Standard (PCI DSS)

Yes	No	Best practice	Explanation
	X	Only authorized users have access to customers' credit card information.	All employees currently have access to stored credit card data, which is a security risk
	X	Credit card information is accepted, processed, transmitted, and stored internally, in a secure environment.	Credit card information is not encrypted making it vulnerable to potential breaches.
	X	Implement data encryption procedures to better secure credit card transaction touchpoints and data.	Encryption is not in use for securing sensitive financial transactions.
	X	Adopt secure password management policies.	The password policy does not meet industry standards for complexity and security.

General Data Protection Regulation (GDPR)

Yes	No	Best practice	Explanation
	X	E.U. customers' data is kept private/secured.	Access controls are weak, allowing unauthorized access to customer data.
X		There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach.	The IT department has a notification plan in case of a security breach.
	X	Ensure data is properly classified and inventoried.	The company has not classified or inventoried its sensitive data.
X		Enforce privacy policies, procedures, and processes to properly document and maintain data.	Privacy policies and procedures are in place and enforced among employees.

System and Organizations Controls (SOC type 1, SOC type 2)

Yes	No	Best practice	Explanation
	X	User access policies are established.	There are no strict access policies restricting who can view or edit sensitive information.
	X	Sensitive data (PII/SPII) is confidential/private.	Customer personally identifiable information (PII) is not properly protected due to lack of access controls and encryption.
X		Data integrity ensures the data is consistent, complete, accurate, and has been validated.	The IT department has implemented controls to maintain data integrity.
	X	Data is available to individuals authorized to access it.	Data availability is ensured, but security controls need improvement.

Recommendations

- To improve Botium Toys' security posture and mitigate identified risks, the following recommendations should be implemented:
- Implement Least Privilege and Role-Based Access Controls: Restrict employee access to sensitive customer data to only those who require it for their job functions.
- Establish a Disaster Recovery Plan: Create and document procedures to recover data and systems in the event of a security incident or failure.

- **Strengthen Password Policies:** Enforce stronger password complexity rules and implement a centralized password management system.
- **Implement Encryption for Sensitive Data:** Encrypt stored credit card information and other sensitive data to ensure confidentiality.
- **Deploy an Intrusion Detection System (IDS):** Implement an IDS to monitor network traffic for signs of cyber threats and respond accordingly.
- **Schedule Regular Backups:** Ensure that all critical data is backed up regularly and stored securely to prevent loss.
- **Develop a Compliance Strategy:** Work towards full compliance with PCI DSS, GDPR, and SOC standards by implementing necessary controls and monitoring processes.